AUDIT REPORT · AUD-2026-IAM-01

Strong authentication and privileged access — KRL-ADM

Crédit Océane (fictif) · Back-office crédits

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:20**

Run: **04-oceane-back-office-presque**

1. Executive summary

OPINION AT TESTING

Broadly satisfactory

7 controls tested	**3** findings	**0** findings closed and verified	**3** open findings
0 human approvals	**26** personal data items masked in evidence	**0 min 22 s** audit duration	**$0.374 *** measured AI cost

Critical: 0 High: 0 Medium: 3 Low: 0

Key messages

- 3 findings across 7 controls: 3 medium.
- 3 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Crédit Océane (fictif)
System	Back-office crédits
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe IAM
Lead auditor	A. Auditeur
Date	2026-11-02 23:20
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.3	Strong password policy	Medium	Non-compliant		Open	2027-05-01
F-02	PSI-4.4	Account lockout after failed logins	Medium	Non-compliant		Open	2027-05-01
F-03	PSI-4.5	Inactive session timeout	Medium	Non-compliant		Open	2027-05-01
—	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Compliant			
—	PSI-4.2	Mandatory MFA for users of critical system	High	Compliant			
—	PSI-4.6	Logging of administration actions	High	Compliant			
—	PSI-4.7	No generic or shared admin accounts	High	Compliant			

4. Detailed findings and controls

F-01 PSI-4.3 Strong password policy — Medium — Non-compliant — Open

CRITERIA

Passwords require a minimum length of 12 characters with complexity requirements enabled
PSI-4.3 · DORA 9(4)(d)

CONDITION

Observed: `{"password_min_length": 11, "password_require_complexity": true}`
Expected: `password_min_length >= 12 AND password_require_complexity == true`
password_min_length is 11 and password_require_complexity is True.

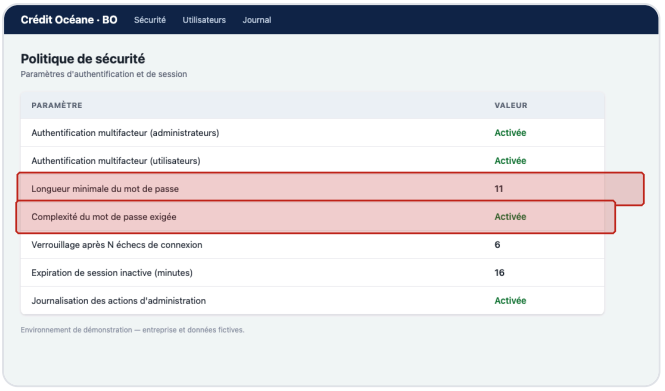
RISK

Weak or short passwords can be guessed or brute-forced, enabling unauthorized access to the system

RECOMMENDATION

Enforce a minimum password length of 12 characters with complexity by correcting the password settings
Due date: 2027-05-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify password_min_length and password_require_complexity



At testing — The screenshot corroborates the test. The screenshot shows minimum password length 11 and complexity Enabled, matching the failed automated result.
`2026-11-02 23:20:19 · SHA-256 2e3c11e99589817f…`

F-02 PSI-4.4 Account lockout after failed logins

Medium · Non-compliant · Open

CRITERIA

Accounts lock after at most 5 failed login attempts and lockout is never disabled
PSI-4.4 · DORA 9(4)(c)

CONDITION

Observed: `6`
Expected: `lockout_threshold >= 1 AND lockout_threshold <= 5`
lockout_threshold is 6, which is outside the required range 1 to 5 inclusive.

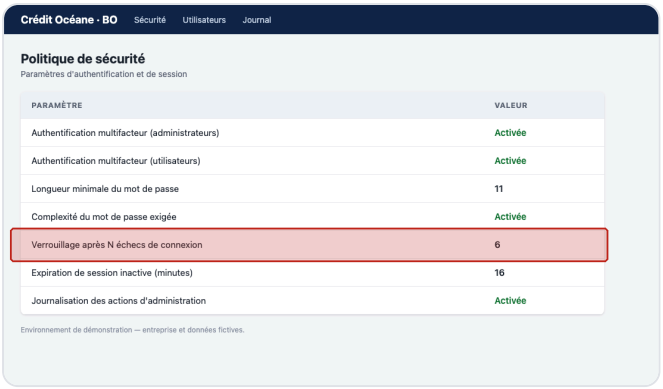
RISK

Without lockout, attackers can perform unlimited password-guessing attacks against accounts

RECOMMENDATION

Configure account lockout to 5 attempts at most by setting lockout_threshold between 1 and 5
Due date: 2027-05-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that lockout_threshold is between 1 and 5 inclusive



At testing — The screenshot corroborates the test. The screenshot shows lockout after 6 failed logins, which exceeds the required maximum of 5.
`2026-11-02 23:20:17 · SHA-256 b1d309b577b0e8c0…`

F-03 PSI-4.5 Inactive session timeout

Medium | Non-compliant | Open

CRITERIA

Inactive sessions expire after at most 15 minutes and expiration is never disabled
PSI-4.5 · DORA 9(4)(c)

CONDITION

Observed: `16`
Expected: `session_timeout_minutes >= 1 AND session_timeout_minutes <= 15`
Observed session_timeout_minutes is 16, outside the required 1 to 15 inclusive.

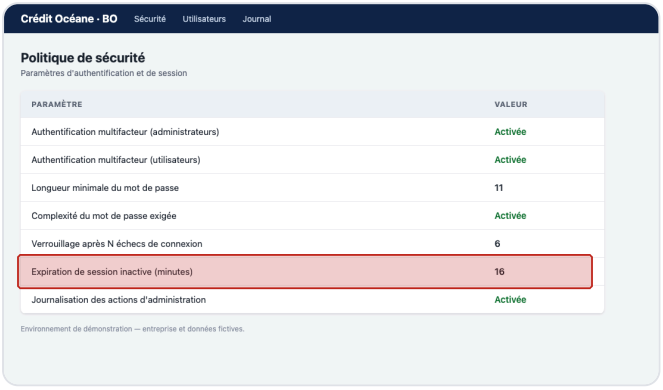
RISK

Unlimited inactive sessions allow session hijacking and unauthorized use of unattended workstations

RECOMMENDATION

Enforce inactive session expiration at 15 minutes at most by setting session_timeout_minutes between 1 and 15
Due date: 2027-05-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that session_timeout_minutes is between 1 and 15 inclusive

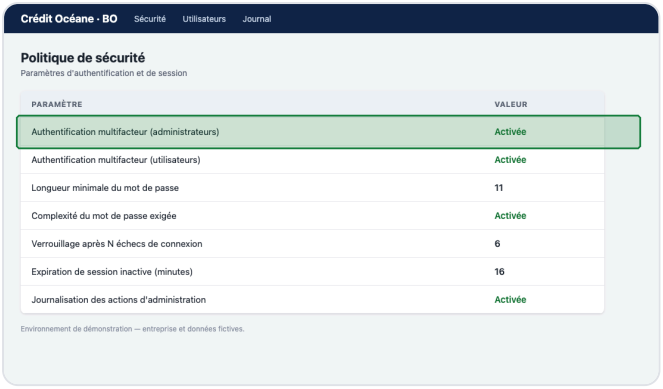


At testing — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 16 minutes, exceeding the 15-minute maximum.
`2026-11-02 23:20:17 · SHA-256 e8481f0c8b55fd43…`

PSI-4.1 Mandatory MFA for privileged accounts

Critical | Compliant

Compliant control — MFA is enforced for all privileged admin accounts on KRL-ADM · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

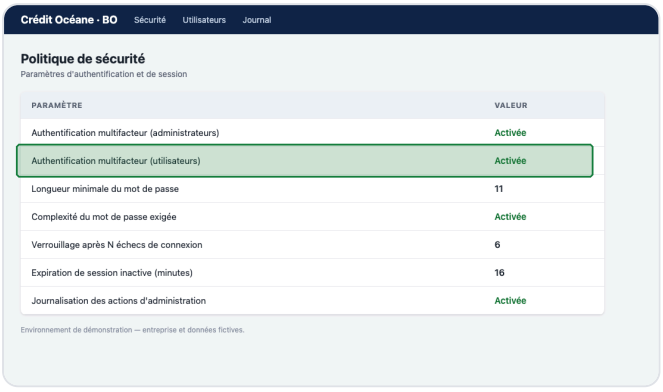


At testing — The screenshot corroborates the test. The security policy table shows administrator MFA as Activée, matching the automated pass result.
`2026-11-02 23:20:20 · SHA-256 a5b9fa7b6b166ec0…`

PSI-4.2 Mandatory MFA for users of critical system

High · Compliant

Compliant control — MFA is enforced for standard users because KRL-ADM supports critical or important functions · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

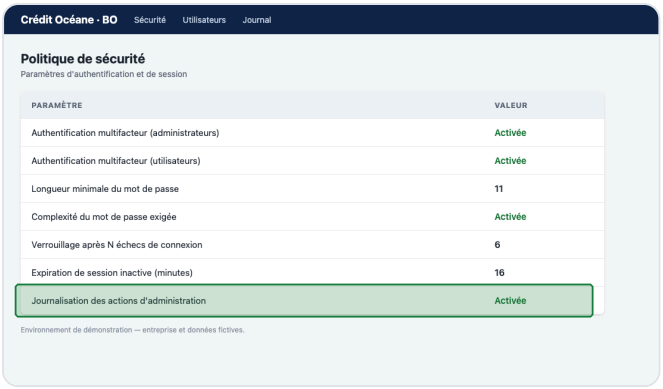


At testing — The screenshot corroborates the test. The screenshot shows user MFA as Activée, confirming mfa_users is true.
`2026-11-02 23:20:17 · SHA-256 90fb2fa589e9a9b8…`

PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`

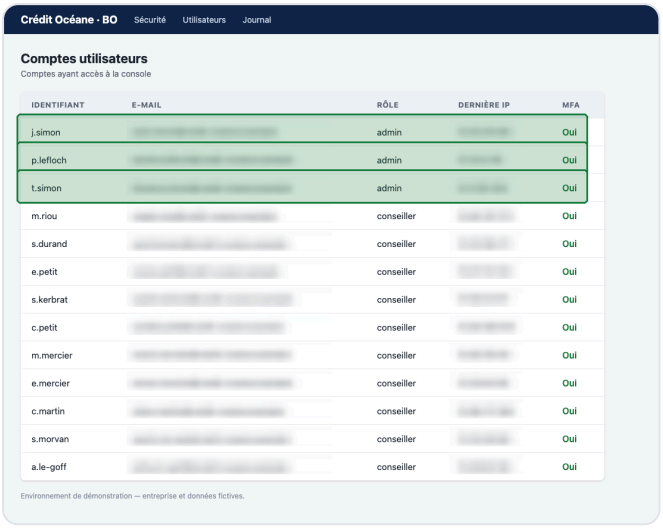


At testing — The screenshot corroborates the test. The screenshot shows administration action logging as enabled.
2026-11-02 23:20:17 · SHA-256 245896cd95379bda…

PSI-4.7 No generic or shared admin accounts

High Compliant

Compliant control — No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)
Observed: `[{"login": "j.simon", "email": "j•••@credit-oceane.example", "role": "admin"}, {"login": "p.lefloch", "email": "p•••@credit-oceane.example", "role": "admin"}, {…`



At testing — The screenshot corroborates the test. The screenshot shows three admin accounts with nominative initiale.nom logins and personal emails matching the automated test result. · 26/26 personal data items masked
2026-11-02 23:20:31 · SHA-256 9c7689e348338533…

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Non-compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Non-compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Non-compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-02 23:20:20	a5b9fa7b6b166ec097e6f16d8af0e83e6bfa78ecfe1b898ce2c42487f8186462
evidence/C2_before.png	C2 · At testing	2026-11-02 23:20:17	90fb2fa589e9a9b803af5f987e5a5aaceb82b6178d00a4258b80731eee6e5665
evidence/C3_before.png	C3 · At testing	2026-11-02 23:20:19	2e3c11e99589817f5a5dc314943fef0c7d16f49d6c8b961047f88dce1e70de55
evidence/C4_before.png	C4 · At testing	2026-11-02 23:20:17	b1d309b577b0e8c0fe1789f2b88837b80b19617daf60e9af15193ae697f99b79
evidence/C5_before.png	C5 · At testing	2026-11-02 23:20:17	e8481f0c8b55fd434d2ff783e5c017c3d39867bd1403f2e6565760fec59e5547
evidence/C6_before.png	C6 · At testing	2026-11-02 23:20:17	245896cd95379bdaeda891bbc609803d7902ba31c6dcb17db7a151db4e75f151
evidence/C7_before.png	C7 · At testing	2026-11-02 23:20:31	9c7689e348338533b3f3756832d80bd4b284dfa44844450a74c43c9d2811c566

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

`muse-spark-1.3`	36	48,808	73,737	0	0.3744
`sam-3.1`	25	0	0	25	price not published
Total					**0.3744**

Personal data in evidence: 26/26 spotted by Muse Spark + SAM, 26/26 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`b89a82791e32c4aca5535d40587076499be9ab64a8202b36f99c20bb25129034`